03 — Roles and Permissions

Prepared 9 November 2026 for teacher review on 10 November. **Draft; not approved or implemented.**

Source: 06-user-roles-and-permissions.md

User roles and permissions

Version: 0.1 · **Prepared:** 9 November 2026 · **Status:** Proposed review draft; no teacher approval or product test execution claimed.

1. Role model

Proposed RBAC model: RBAC means role-based access control. An account can hold multiple explicitly assigned roles. Permissions combine only within their authorized resource scopes. Having a system role does not automatically make someone a teacher, a classroom participant or a network administrator. Student participation may use a session-scoped identity instead of a permanent account; D03 must settle that model.

Role	Main responsibility	Explicit boundary
System Administrator — SYS	Provision application accounts/roles, application settings, policy profiles and application audit/health access	No automatic teacher publishing, student media access or infrastructure configuration rights
Teacher — TCH	Create and run owned classes; publish screen/audio; admit/remove/block participants; select an approved profile assigned to the class	Cannot edit DNS/router settings, see secrets, expand network scope or edit policy rules using the Teacher role alone
Student — STU	Request admission; view/listen in an admitted class; use permitted materials/participation features	Cannot publish teacher media, control the classroom, manage other students or change policies
IT / Network Administrator — NET	Provision approved DNS/gateway/router integrations and network scopes; manage network policy operations, verification and recovery	Application privileges do not substitute for campus IT authorization or infrastructure-owner permission

In F09/F17, “Administrator” means SYS or NET with the named policy permission and assigned scope. Network credentials, integration settings and scope provisioning are NET-only. SYS policy-profile editing is a proposed allocation of NAC16, not a source requirement that every system administrator can change campus rules.

Account/role assignment is recorded with actor, target and timestamp. A newly granted NET role still needs an authorized integration scope. Proposed rule: SYS maintains role assignments through the agreed approval process; NET scope access is granted only after the network authority approves it. Prevent removal of the last recoverable SYS account; emergency account recovery is an operational procedure to define in D14.

2. Permission matrix

Legend: Allow = role grants this action; Own = only owned classes/resources; Scoped = only assigned approved enforcement scopes; Limited = the condition stated below applies; Deny = no permission from this role. No row grants access outside the resource boundary. These are proposed server-side authorization rules.

Permission / operation	SYS	TCH	STU	NET	Scope or condition
Create/deactivate application users	Allow	Deny	Deny	Deny	No access to plaintext passwords; audit changes
Assign/revoke application roles	Allow	Deny	Deny	Deny	Controlled process; NET scope authorization remains separate
Configure application settings	Allow	Deny	Deny	Limited	NET only changes assigned integration configuration
Create classroom	Deny	Allow	Deny	Deny	Account must have Teacher role
Read/manage classroom and roster	Deny	Own	Limited	Deny	Student sees own admitted session state, not the full roster by default
Start/pause/resume/stop teacher publication	Deny	Own	Deny	Deny	Server grants publisher permission; browser capture consent still required
Change media quality	Deny	Own	Deny	Deny	Supported capture/encoder settings only
Request classroom admission	Deny	Deny	Allow	Deny	Valid code and session state; no automatic admission
Receive classroom media	Deny	Limited	Limited	Deny	Teacher preview for own class; Student only after current admission
Approve/reject/remove/block participants	Deny	Own	Deny	Deny	Server verifies ownership and target class
End classroom	Deny	Own	Deny	Deny	Backend closes access and triggers required restoration
Change own volume/fullscreen	Deny	Limited	Limited	Deny	Only one's own authorized playback
Read policy profiles	Scoped	Limited	Deny	Scoped	Teacher sees only approved profiles assigned for own classes
Create/edit policy profiles and exceptions	Scoped	Deny	Deny	Scoped	Validate protected local services and version changes

Permission / operation	SYS	TCH	STU	NET	Scope or condition
Approve profiles for a network scope	Deny	Deny	Deny	Scoped	Proposed network-authority approval; D15 confirms process
Select approved profile for class	Deny	Own	Deny	Deny	Cannot edit rules or choose an unauthorized network scope
Apply/disable policy manually	Scoped	Deny	Deny	Scoped	Assigned scope and approved profile; preserve prior state
Trigger preapproved policy through class start/end	Deny	Own	Deny	Deny	Backend automation rechecks profile/scope approval; not arbitrary infrastructure access
Emergency restore ClassroomCast changes	Scoped	Deny	Deny	Scoped	Does not disable unrelated campus controls; audited
Request emergency help/restore	Allow	Own	Deny	Allow	Teacher requests action; request itself changes no policy
Configure DNS/router/gateway, credentials or scopes	Deny	Deny	Deny	Scoped	Network owner authorization required; secrets stay server-side
Read enforcement status	Scoped	Own	Deny	Scoped	Teacher sees assigned class summary without secrets/device browsing history
Schedule/import/export profiles — Should	Scoped	Deny	Deny	Scoped	Validate scope; no credentials in exports
Target group/device policy — Could	Scoped	Deny	Deny	Scoped	Only where adapter can identify and isolate authorized target
Upload/share class materials — Should	Deny	Own	Deny	Deny	Validate size/type and class permissions
View/download materials — Should	Deny	Own	Limited	Deny	Student admitted and teacher permits requested action
Submit hand/question/poll response — Could	Deny	Deny	Limited	Deny	Admitted student; activity open where applicable
Read class history/results — Could	Deny	Own	Deny	Deny	Limited to retained authorized summaries; not a video recording feature
View audit records	Limited	Limited	Deny	Limited	SYS: application/policy audit; Teacher: own class actions; NET: assigned network scopes; redact secrets and unrelated identities

Permission / operation	SYS	TCH	STU	NET	Scope or condition
View health/diagnostics	Limited	Limited	Limited	Limited	SYS: app health; Teacher: own class/media; Student: own connection; NET: assigned infrastructure health
Restart/reconfigure host services	Deny	Deny	Deny	Limited	Authorized operator procedure/host access; no new web restart endpoint is implied

3. Authorization checks

1. Default deny: backend endpoints, application events and media-room grants enforce permissions. Hiding a UI button is insufficient.
2. Check the action **and** resource: Teacher A cannot control Teacher B's class even with a valid Teacher role. Admission/media access is class-scoped.
3. Backend automation acts on the recorded class/profile/scope authorization. It has no independent permission to modify an arbitrary network.
4. Revoke current admission/media grants when a participant is removed, blocked or the class ends. Reconnect must recheck current state; identity persistence limits stay explicit.
5. Ordinary student media grants are subscribe-only. SYS/NET do not get media access unless separately holding the appropriate scoped Teacher/Student permission.
6. Never return network credentials or API signing secrets in frontend bundles, policy exports, status responses or logs.
7. Record privileged outcomes with actor/service identity, scope, timestamp and result. Do not turn audit logging into student browsing-history collection.
8. Test each matrix row with allow and deny cases, including cross-class access, unauthorized network scope, revoked admission and expired/forged media credentials. Map representative tests to AC-AUTH and TC-NAC16 below.

4. Actor versus service

Component or external authority	Responsibility	Boundary
Backend / application service	Enforce permissions; manage sessions, admission, policy lifecycle and audit	Validate action and class/network scope on every protected request
Local SFU / media service	Receive teacher publication and forward media to authorized viewers	Publishing/subscription grants are class-scoped; Student is subscribe-only
Network enforcement service	Apply supported DNS/gateway rules and expose operation/read-back results	It controls only supported, authorized traffic paths; does not prove universal blocking

Component or external authority	Responsibility	Boundary
Local database and recovery worker	Persist sessions, profile versions, prior policy and outstanding recovery operations	Closing a browser must not discard expiry/restoration work
Campus IT / infrastructure owner	Authorize hosting, certificates, reachability and network-control integration	Application NET role does not replace the infrastructure owner's authorization